Risk Evaluation Methods

Multi-Criteria Risk Scoring · Business Impact Analysis · Critical Asset Risk Exposure Register

Builds on the HVMC risk register (16 risks) and live Azure configuration evidence

Project Name	Healthcare IAM Operations Simulation
Organization	Horizon Valley Medical Center (HVMC)
Rubric	Risk Evaluation Methods (Semester 4, Week 10)
Builds on	Risk Management Fundamentals (governance, HIPAA matrix); Risk Assessment Techniques (16-risk register, ALE)
Companion file	**HVMC_Risk_Evaluation_Workbook.xlsx** — criteria & AHP weights, weighted scoring, BIA calculator, exposure register, approval log (live formulas)
Prepared By	Sabitha S Karanavar
Report Date	October 14, 2026

Rubric Cross-Reference

Rubric requirement	Section	Evidence
Multi-criteria risk scoring model with weighted evaluation factors (financial, operational, compliance, reputation) and defined measurement scales	2	Four 1–5 scales with written definitions; weights derived by AHP (CR = 0.017); all 16 risks re-scored and compared with the 5×5 ranking
Business Impact Analysis with RTO, RPO and MTD calculations	3.1–3.2	MTD, RTO and RPO calculated by formula for 9 systems and inherited by 3 supporting services
Financial impact analysis	3.3	Hourly impact model and cost at 1, 4, 8, 24, 72 hours and at MTD
Dependency mapping	3.4	Dependency diagram, single points of failure, current capability vs. target
Evaluation criteria documented with stakeholder approval	4	Criteria summary, approval table with 7 approvers, review cycle and version control
Critical asset risk exposure register (threat exposure, vulnerabilities, interconnection dependencies), professionally formatted	5 + Excel	11 assets with ATT&CK threats, evidenced vulnerabilities, upstream/downstream links, exposure rating and ALE

Key results: Weights: Operational **36%**, Compliance **33%**, Financial **19%**, Reputation **12%**. Weighted ratings: High 5 · Medium 7 · Low 4. Tier 1 systems (EHR, LIS, Pharmacy) need RTOs of **2–4 hours**. The EHR's MTD is set by patient safety at **8 h**, when an outage has cost **$80,075**. The largest exposures are concentrated on **hvmcehrstorage**, the **EHR**, and **Entra ID**, which every system depends on.

2. Multi-Criteria Risk Scoring Model

The Risk Assessment rated each risk with one impact score. A single impact number hides *what kind* of harm a risk causes. A data breach and a multi-day outage can both score 5, yet they hurt HVMC in different ways. The multi-criteria model scores impact on four factors separately and combines them with weights agreed by stakeholders.

2.1 Evaluation factors and measurement scales

Score	Financial	Operational	Compliance	Reputation
1	< $10K	No service impact	No regulatory issue	No external awareness
2	$10K – $100K	Non-clinical service degraded < 4 h	Internal policy breach only	Individual patient complaints
3	$100K – $500K	Clinical workflow on downtime procedures < 24 h	HIPAA violation < 500 records (annual HHS log)	Local media coverage
4	$500K – $2M	Clinical system down 1–3 days, or temporary patient harm possible	Reportable breach ≥ 500 records; OCR investigation	Regional media; measurable patient attrition
5	> $2M	Clinical system down > 3 days, or serious patient harm	OCR Tier 3–4 penalty / corrective action plan; state AG action	National media; lasting loss of trust

Financial bands match the impact scale used in the Risk Assessment. Patient safety is assessed within Operational, because care disruption is how most security events harm patients. Likelihood keeps the existing 1–5 scale (Rare to Almost certain).

2.2 Deriving the weights — Analytic Hierarchy Process (AHP)

Weights were not assigned by intuition. Stakeholders compared the factors **two at a time** on Saaty's 1–9 scale (1 = equal, 3 = moderately more important). The weights are the normalized geometric means of each row, and a consistency check confirms the judgments don't contradict each other.

Row vs column	Financial	Operational	Compliance	Reputation	Geometric mean	Exact weight	Weight used
Financial	1	1/2	1/2	2	0.841	19.3%	**19%**
Operational	2	1	1	3	1.565	35.9%	**36%**
Compliance	2	1	1	2	1.414	32.5%	**33%**
Reputation	1/2	1/3	1/2	1	0.537	12.3%	**12%**

Comparison	Value	Stakeholder rationale
Operational vs Financial	2	Care continuity and patient safety matter more than cost for a hospital
Compliance vs Financial	2	HIPAA violations carry penalties, corrective action plans and loss of trust beyond direct cost
Financial vs Reputation	2	Direct loss is more certain and measurable than reputational effect
Operational vs Compliance	1	Equally important — both are core obligations of a covered entity
Operational vs Reputation	3	Clinical disruption harms patients directly; reputation follows from it
Compliance vs Reputation	2	Regulatory outcomes are the main driver of public reputation in healthcare breaches

$$\lambda_{max} = 4.046 \;\cdot\; CI = (\lambda_{max} - n)/(n-1) = 0.0152 \;\cdot\; CR = CI \,/\, RI(0.90) = \mathbf{0.017} < 0.10 \;\checkmark$$

A consistency ratio below 0.10 means the pairwise judgments are coherent, so the weights can be used.

2.3 Scoring formula and decision rules

$$\text{Weighted Impact (WI)} = 0.19 \cdot F + 0.36 \cdot O + 0.33 \cdot C + 0.12 \cdot R \quad (1\text{–}5)$$

$$\text{Weighted Risk Score} = \text{Likelihood} \times \text{WI} \quad (1\text{–}25)$$

- **Bands** (unchanged from Risk Management Fundamentals): Critical ≥ 20 · High 12–19.99 · Medium 6–11.99 · Low < 6.
- **Critical-factor floor:** a risk with any factor at 5 and likelihood ≥ 3 is rated at least **High**, so one severe consequence cannot be averaged away. This applied to R02, whose ePHI exposure scores 5 on Financial and Compliance.
- **Patient-safety escalation:** Operational = 5 is always reported to the Security & Risk Lead, whatever the final rating.

2.4 Results — all 16 risks re-scored

ID	Risk	L	F	O	C	R	WI	Score	Rating	Previous 5×5	Rank
R01	Security incident goes undetected for months (no central logging or alerting)	4	5	3	5	4	4.16	**16.64**	High	20 Critical	1 → **1**
R05	Ransomware or malicious deletion destroys EHR data	3	5	5	4	5	4.67	**14.01**	High	15 High	5 → **2**
R03	Lateral movement from Web tier to Data tier	3	5	4	5	4	4.52	**13.56**	High	15 High	4 → **3**
R10	Remote code execution via Apache 2.4.7 mod_lua (CVE-2021-44790, CVSS 9.8)	4	4	3	3	3	3.19	**12.76**	High	20 Critical	2 → **4**
R02	ePHI exfiltration from EHR storage over the public internet	3	5	2	5	5	3.92	**11.76**	High floor rule	15 High	3 → **5**
R11	Malware uploaded to EHR storage is not detected	3	3	4	3	3	3.36	**10.08**	Medium	12 High	9 → **6**
R04	Loss or takeover of the only Global Administrator account	3	3	4	3	2	3.24	**9.72**	Medium	12 High	7 → **7**
R09	Remote code execution via OpenSSH 6.6.1p1 (CVE-2023-38408, CVSS 9.8)	3	4	3	3	3	3.19	**9.57**	Medium	15 High	6 → **8**
R08	Consent phishing or rogue app via open tenant settings	3	3	2	4	3	2.97	**8.91**	Medium	12 High	8 → **9**
R12	Clinician credentials stolen by MFA-bypass (AiTM) phishing	3	3	2	4	3	2.97	**8.91**	Medium	12 High	10 → **10**
R13	Workforce member views patient records without a care need (snooping)	3	2	1	4	4	2.54	**7.62**	Medium	12 High	11 → **11**
R16	Breach notification deadline missed (no Privacy Officer)	2	3	1	5	4	3.06	**6.12**	Medium	8 Medium	15 → **12**
R15	Accidental deletion of production network or storage	2	3	4	2	2	2.91	**5.82**	Low	8 Medium	14 → **13**
R06	Contractor retains access after engagement ends; no BAA	2	2	1	4	2	2.30	**4.60**	Low	8 Medium	12 → **14**
R14	Workforce violations go unpunished; training not tracked	2	2	1	3	2	1.97	**3.94**	Low	8 Medium	13 → **15**
R07	Shared test account in production can read ePHI	2	1	1	3	2	1.78	**3.56**	Low	6 Medium	16 → **16**

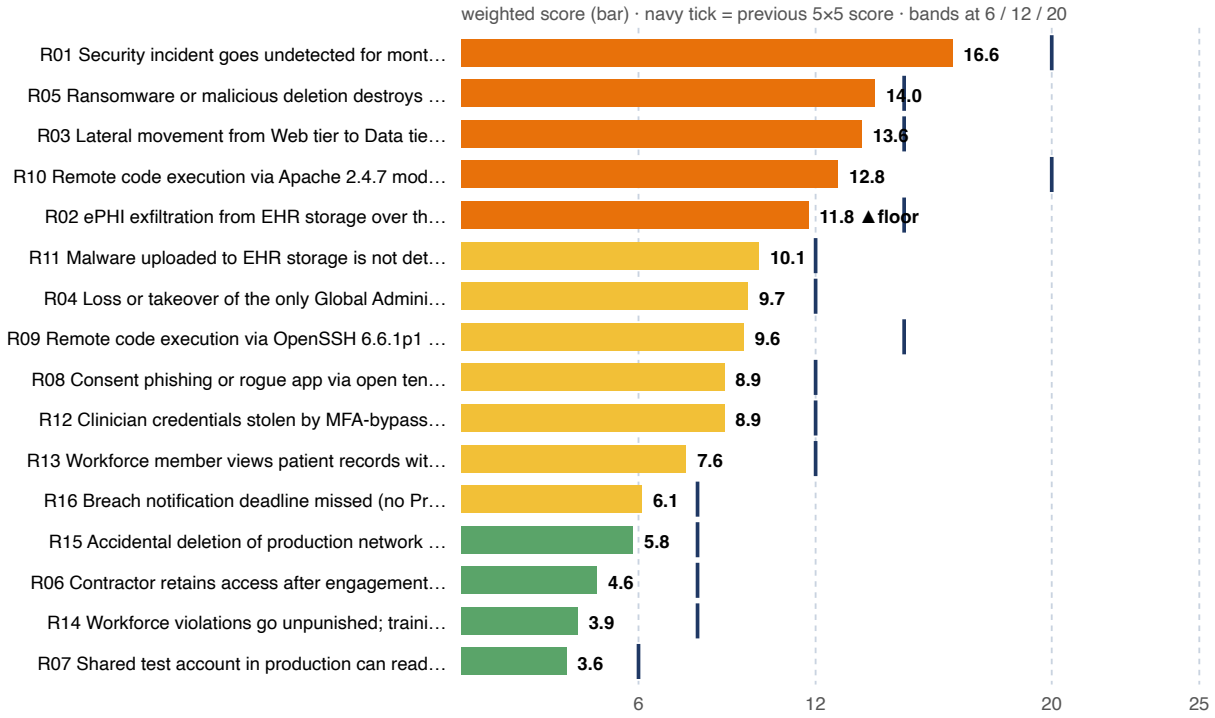


Figure 1 — Weighted risk scores (bars) against the previous 5×5 scores (navy ticks).

2.5 What the weighted model changed

- **Biggest rises:** R05 (#5 → #2), R11 (#9 → #6), R16 (#15 → #12). Their operational or compliance consequences were under-weighted by a single impact score. Ransomware (R05) and Data-tier lateral movement (R03) now rank directly behind R01.
- **Biggest falls:** R10 (#2 → #4), R02 (#3 → #5), R09 (#6 → #8). R10 and R09 affect a legacy lab server that holds no ePHI, so their compliance and reputation scores are moderate; R10 moves from Critical to High. R02 scores lower because the EHR keeps running during a data exposure (Operational 2), but the critical-factor floor keeps it High.
- 11 of 16 risks changed rank. The top three priorities (R01, R05, R03) all involve **detection, recovery or segmentation of ePHI systems**, which is where mitigation money should go first (next rubric).

Factor-scoring rationale

ID	Why the factor scores were chosen
R01	Undetected breach multiplies cost; HIPAA audit-control failure; delayed disclosure draws media
R02	Bulk ePHI exposure: breach cost + OCR investigation + national coverage; EHR keeps running
R03	Database compromise allows ePHI theft and dose/result tampering (patient safety)
R04	Admin lockout halts recovery and change for days; limited direct data exposure
R05	Multi-day EHR outage, ambulance diversion, unrecoverable records
R06	Unmanaged third-party access is a HIPAA BA violation; little operational effect
R07	Untraceable ePHI read access violates unique-ID standard
R08	Malicious app reads user data; OCR-reportable if PHI involved
R09	Host takeover; legacy lab target, no ePHI stored
R10	Public web server compromise; legacy lab target, no ePHI stored
R11	Malware spreads to clinical workstations; downtime procedures needed
R12	One clinician's EHR access misused; limited record count
R13	Snooping is the most common OCR complaint; strong patient-trust impact

ID	Why the factor scores were chosen
R14	Missing required policy; finding in any OCR audit
R15	Portal down until rebuilt; no data loss if storage survives
R16	Late notification is a separate §164.404 violation; public criticism

3. Business Impact Analysis

The BIA follows NIST SP 800-34 Rev. 1 and supports the HIPAA **applications and data criticality analysis** (§164.308(a)(7)(ii)(E)). For each system it answers: how long can HVMC be without it (MTD), how fast must it be restored (RTO), and how much data can be lost (RPO)?

3.1 Method and assumptions

Item	Definition / value
Organization profile (simulated)	150-bed hospital, $90,000,000 annual net patient revenue → **$10,274** per hour; internal labour $75/hour
Hourly impact	(share of revenue depending on the system × hourly revenue) + extra labour for manual workarounds + other direct costs
MTD — Maximum Tolerable Downtime	MTD = **min**(financial tolerance ÷ hourly impact, patient-safety limit, policy maximum). The patient-safety limit is how long paper downtime procedures stay safe, as set by the clinical owner.
RTO — Recovery Time Objective	RTO ≤ MTD − WRT − 1 h (detection and decision), rounded **down** to a standard tier (1, 2, 4, 8, 12, 24, 48, 72 h). WRT is the work recovery time to verify data and catch up after restore.
RPO — Recovery Point Objective	RPO = maximum transactions staff can re-enter from paper ÷ transactions per hour
Supporting services	Inherit the **strictest** MTD/RTO/RPO of the systems that depend on them
Criticality tier	Tier 1: MTD ≤ 8 h · Tier 2: ≤ 24 h · Tier 3: > 24 h

3.2 MTD, RTO and RPO results

System / process	Owner	Hourly impact	Hours to financial tolerance	Safety limit	Policy max	MTD (driver)	WRT	RTO	RPO	Tier
EHR (clinical documentation & orders) Patient care documentation, CPOE	Sarah Chen	$6,884	21.8 h	8 h	72 h	**8 h** patient-safety limit	3 h	**4 h**	**15 min** 100 ÷ 400/h	Tier 1
Laboratory Information System Lab orders, results, critical-value calls	Elena Petrova	$2,527	23.7 h	4 h	72 h	**4 h** patient-safety limit	1 h	**2 h**	**30 min** 60 ÷ 120/h	Tier 1
Pharmacy Management System Medication verification & dispensing	David Patel	$1,782	28.1 h	6 h	72 h	**6 h** patient-safety limit	1 h	**4 h**	**15 min** 20 ÷ 80/h	Tier 1
Appointment Scheduling Registration, appointments	Grace Nguyen	$634	63.1 h	—	72 h	**63.1 h** financial tolerance	4 h	**48 h**	**4 h** 120 ÷ 30/h	Tier 3
Payroll Staff pay runs	Brian Adeyemi	$150	133.3 h	—	72 h	**72 h** policy maximum	8 h	**48 h**	**8 h** 40 ÷ 5/h	Tier 3
HR Portal Hiring, leave, staff records	Daniel Osei	$100	200 h	—	72 h	**72 h** policy maximum	4 h	**48 h**	**24 h** 120 ÷ 5/h	Tier 3
Security Monitoring Portal Alert triage, audit review	Denise Coleman	$200	100 h	—	24 h	**24 h** policy maximum	2 h	**12 h**	**4 h** 200 ÷ 50/h	Tier 2

System / process	Owner	Hourly impact	Hours to financial tolerance	Safety limit	Policy max	MTD (driver)	WRT	RTO	RPO	Tier
IT Administration Console Configuration & change	Kevin O'Brien	$250	120 h	—	24 h	**24 h** policy maximum	2 h	**12 h**	**4 h** 40 ÷ 10/h	Tier 2
VPN Portal Contractor remote access	Kevin O'Brien	$50	200 h	—	72 h	**72 h** policy maximum	1 h	**48 h**	**10 h** 20 ÷ 2/h	Tier 3

Worked example — EHR: hourly impact = 0.60 × $10,274 + $720 labour = **$6,884**. Financial tolerance $150,000 ÷ $6,884 = 21.8 h. The patient-safety limit is 8 h and the policy maximum 72 h, so **MTD = 8 h (patient safety)**. RTO ≤ 8 – 3 (WRT) – 1 = 4 h → **RTO 4 h**. RPO = 100 re-enterable orders ÷ 400 per hour = **15 min**.

Supporting services (inherited requirements)

Service	Owner	Used by	MTD	RTO	RPO	Impact if down
Entra ID (identity) Microsoft SaaS (SLA 99.99%)	Sabitha S Karanavar	All 9 systems	4 h	2 h	15 min	$12,577/h
HVMC-Prod-VNet / LB / NAT Network: Web 10.0.1.0/24, App 10.0.2.0/24, Data 10.0.3.0/24	Fatima Ali	EHR, LIS, Pharmacy	4 h	2 h	15 min	$11,194/h
hvmcehrstorage ePHI blob storage, Standard_RAGRS	Sarah Chen	EHR	8 h	4 h	15 min	$6,884/h

3.3 Financial impact analysis

System	One-time recovery	1 h	4 h	8 h	24 h	72 h	Cost at MTD
EHR (clinical documentation & orders)	$25,000	$31,884	$52,538	$80,075	$190,225	$520,676	**$80,075**
Laboratory Information System	$8,000	$10,527	$18,110	$28,219	$68,658	$189,973	**$18,110**
Pharmacy Management System	$8,000	$9,782	$15,128	$22,255	$50,766	$136,298	**$18,692**
Appointment Scheduling	$3,000	$3,634	$5,535	$8,070	$18,209	$48,626	**$43,000**
Payroll	$2,000	$2,150	$2,600	$3,200	$5,600	$12,800	**$12,800**
HR Portal	$2,000	$2,100	$2,400	$2,800	$4,400	$9,200	**$9,200**
Security Monitoring Portal	$4,000	$4,200	$4,800	$5,600	$8,800	$18,400	**$8,800**
IT Administration Console	$4,000	$4,250	$5,000	$6,000	$10,000	$22,000	**$10,000**
VPN Portal	$1,000	$1,050	$1,200	$1,400	$2,200	$4,600	**$4,600**

An Entra ID outage stops all nine systems at once, about **$12,577/hour**. That's why identity resilience (break-glass account, second admin) ranks as a Tier 1 dependency even though Entra ID itself is a Microsoft-run service. Downtime cost grows linearly, but harm does not: after the MTD, clinical risk rises sharply, which is why MTD rather than cost drives the Tier 1 RTOs.

3.4 Dependency mapping

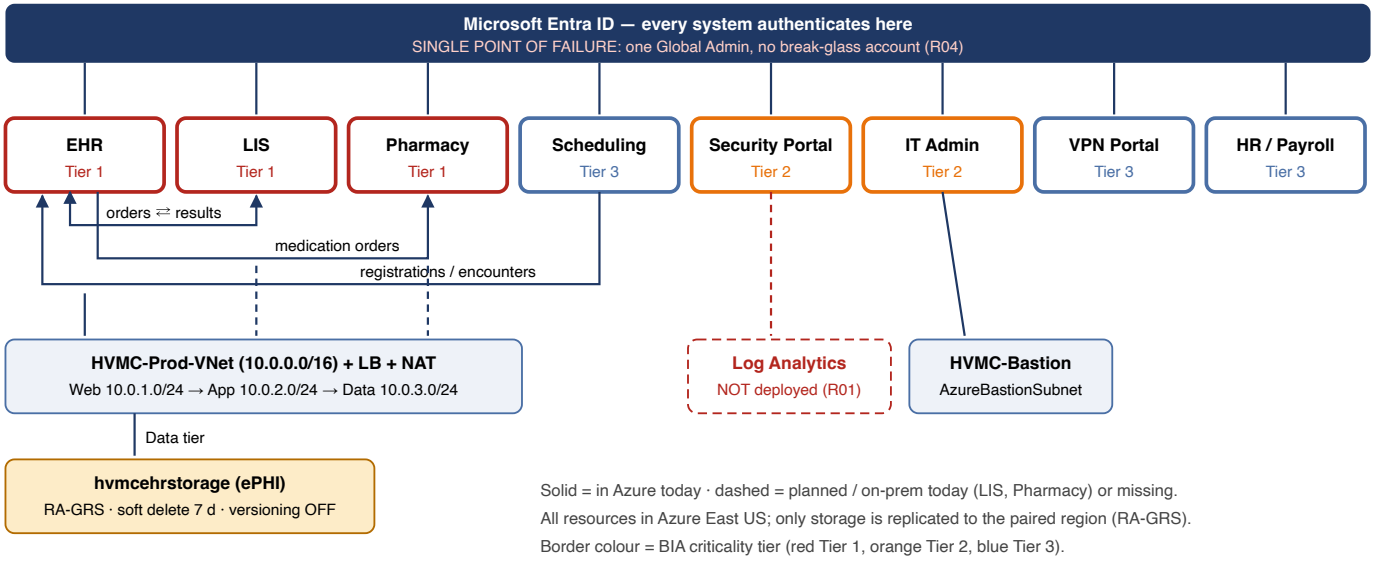


Figure 2 — HVMC system dependency map.

Single points of failure: (1) Entra ID with one Global Admin; (2) the Data subnet, which serves every clinical system; (3) one Azure region for compute and network (only storage is geo-replicated); (4) no central logging, so the Security Portal has nothing to monitor.

Current recovery capability vs. BIA targets

System	Target RTO / RPO	Current capability (live Azure evidence)	Achievable RTO	Achievable RPO	Status
EHR (clinical documentation & orders)	4 h / 15 min	No compute deployed in subscription (0 VMs); no DR runbook or tested restore	Not established	Not established	**Gap**
Laboratory Information System	2 h / 30 min	Not yet migrated to Azure; on-prem recovery untested	Not established	Not established	**Gap**
Pharmacy Management System	4 h / 15 min	Not yet migrated to Azure; on-prem recovery untested	Not established	Not established	**Gap**
hvmcehrstorage	4 h / 15 min	RA-GRS geo-replication (Microsoft-stated RPO typically < 15 min for regional failover); soft delete 7 days; versioning OFF, so overwritten/encrypted blobs cannot be rolled back	≈1 h (customer-initiated failover)	< 15 min regional / unbounded for overwrite	**Partial**
Entra ID (identity)	2 h / 15 min	Microsoft-operated; single Global Admin, no break-glass account (risk R04)	Microsoft SLA	n/a	**Partial**

4. Evaluation Criteria and Stakeholder Approval

4.1 Approved evaluation criteria (summary)

Criterion	Approved value	Section
Impact factors and scales	Financial, Operational, Compliance, Reputation; each 1–5 with written definitions	2.1
Factor weights	Financial 19%, Operational 36%, Compliance 33%, Reputation 12% (AHP, CR 0.017)	2.2
Scoring formula and bands	Likelihood × Weighted Impact; Critical ≥ 20, High ≥ 12, Medium ≥ 6	2.3
Override rules	Critical-factor floor; patient-safety escalation	2.3
BIA tolerances	Per-system financial tolerances, patient-safety limits and policy maxima	3.1–3.2
BIA calculation rules	MTD = minimum of limits; RTO ≤ MTD − WRT − 1 h (tiered); RPO = re-entry capacity ÷ transaction rate	3.1
Review cycle	Annually, and after a major incident, a new or migrated system, or a regulatory change	4.3

4.2 Approval record

This is a lab simulation: approvals are recorded as simulated, using the roles defined in the HVMC governance structure. Signature lines are left blank for real sign-off if required.

Name	Role	Reviewed	Approval role	Decision	Signature	Date
Denise Coleman	Security Supervisor / HIPAA Security Officer	Overall criteria, compliance scale	Owner	Approved (simulated)	_____	2026-10-14
Kevin O'Brien	IT Manager / IT Risk Owner	Operational scale, RTO/RPO feasibility	Approver	Approved (simulated)	_____	2026-10-14
Brian Adeyemi	Finance Manager	Financial scale, BIA cost assumptions	Approver	Approved (simulated)	_____	2026-10-14
Sarah Chen	Physician, EHR Data Owner	Patient-safety limits, clinical MTDs	Approver	Approved (simulated)	_____	2026-10-14
Elena Petrova	Lab Manager, LIS Owner	LIS MTD/RPO	Reviewer	Approved (simulated)	_____	2026-10-14
David Patel	Pharmacist, Pharmacy System Owner	Pharmacy MTD/RPO	Reviewer	Approved (simulated)	_____	2026-10-14
Executive Risk Committee	CEO, CFO, CMO (not modeled in tenant)	Final approval of weights and tolerances	Final approver	Approved (simulated)	_____	2026-10-14

4.3 Version control

Version	Date	Change	Approved by
1.0	2026-10-14	Initial criteria, AHP weights, BIA tolerances and rules	Executive Risk Committee (simulated)

5. Critical Asset Risk Exposure Register

Each critical asset is shown with the threats it faces, the evidenced vulnerabilities that expose it, the risks that link the two, and the assets it depends on or supports. **Exposure** is the highest weighted risk score among its linked risks. ALE comes from the Risk Assessment and overlaps between assets, so the figures are not additive.

Asset	Tier / CIA	Threat exposure (MITRE ATT&CK)	Vulnerabilities (evidence)	Risks	Exposure	ALE	Depends on	Used by
hvmcehrstorage ePHI data store (Azure Storage) Owner: Sarah Chen	Tier 1 C High · I High · A Mod	T1530 Data from Cloud Storage T1486 / T1485 Ransomware, Data Destruction T1078 Valid Accounts (shared test account) T1105 Ingress Tool Transfer (malware)	V02 public network access Enabled, firewall default Allow, shared-key access enabled; V05 blob versioning off, soft delete only 7 days, 0 resource locks, restore never tested; V07 Test Nurse - EHR holds HVMC-Nurse-EHR-ReadOnly on hvmcehrstorage; V11 all Defender for Cloud workload plans on Free tier; 0 security contacts configured	R02, R05, R07, R11	High 14.01 (R05)	$1,657,776	Entra ID (RBAC), HVMC-Prod-VNet, Azure East US + paired region	EHR, Nurse read-only role
EHR application Clinical system Owner: Sarah Chen	Tier 1 C High · I High · A High	T1021 Remote Services (lateral movement) T1486 / T1485 Ransomware, Data Destruction T1566 / T1557 Phishing, Adversary-in-the-Middle Insider misuse (record snooping)	V03 HVMC-Data-NSG has no deny rule; default AllowVnetInBound (65000) permits Web→Data on any port; V05 blob versioning off, soft delete only 7 days, 0 resource locks, restore never tested; V12 security defaults allow push/OTP MFA; no Conditional Access or phishing-resistant MFA; V13 no record-level access auditing or monthly access-log review	R03, R05, R12, R13	High 14.01 (R05)	$1,300,273	Entra ID, Web/App/Data subnets, hvmcehrstorage	Clinicians (12), LIS, Pharmacy, Scheduling
HVMC-Prod-VNet — Data subnet Network segment 10.0.3.0/24 Owner: Fatima Ali	Tier 1 C High · I High · A High	T1021 Remote Services (lateral movement) Administrator error (deletion)	V03 HVMC-Data-NSG has no deny rule; default AllowVnetInBound (65000) permits Web→Data on any port; V15 0 resource locks on the production resource group	R03, R15	High 13.56 (R03)	—	HVMC-Data-NSG, HVMC-CloudSecurity-RG	EHR database (SQL 1433)
Pharmacy Management System Clinical system Owner: David Patel	Tier 1 C Mod · I High · A High	T1021 Remote Services (lateral movement) Insider misuse (record snooping)	V03 HVMC-Data-NSG has no deny rule; default AllowVnetInBound (65000) permits Web→Data on any port; V13 no record-level access auditing or monthly access-log review	R03, R13	High 13.56 (R03)	$74,960	Entra ID, network, EHR orders	Pharmacists (3), nursing medication administration

Asset	Tier / CIA	Threat exposure (MITRE ATT&CK)	Vulnerabilities (evidence)	Risks	Exposure	ALE	Depends on	Used by
Entra ID tenant Identity platform (SaaS) Owner: Sabitha S Karanavar	Tier 1 C High · I High · A High	T1078.004 Valid Cloud Accounts (admin) T1078 Valid Accounts (third party) T1528 Steal Application Access Token T1566 / T1557 Phishing, Adversary-in-the-Middle	V04 1 Global Administrator, no break-glass account, same person is subscription Owner; V06 Carlos Diaz account has no expiry date; no business associate agreement on file; V08 any user can register apps and create tenants; guest invites allowed from everyone; V12 security defaults allow push/OTP MFA; no Conditional Access or phishing-resistant MFA	R04, R06, R08, R12	**Medium** 9.72 (R04)	$168,180	Microsoft cloud; one Global Admin account	All 9 HVMC systems, Azure RBAC, VPN
Laboratory Information System Clinical system Owner: Elena Petrova	Tier 1 C Mod · I High · A Mod	T1566 / T1557 Phishing, Adversary-in-the-Middle Insider misuse (record snooping)	V12 security defaults allow push/OTP MFA; no Conditional Access or phishing-resistant MFA; V13 no record-level access auditing or monthly access-log review	R12, R13	**Medium** 8.91 (R12)	$243,140	Entra ID, network, EHR order feed	EHR (results), clinicians
Security Monitoring Portal Security operations Owner: Denise Coleman	Tier 2 C Mod · I High · A Mod	T1562.008 Disable Cloud Logs Process failure (late breach notice)	V01 0 Log Analytics workspaces, 0 activity-log diagnostic settings, 0 alert rules, 0 NSG flow logs; V16 Privacy Officer role vacant	R01, R16	**High** 16.64 (R01)	$864,926	Entra ID, Log Analytics (not deployed)	Incident response, HIPAA audit review
IT Administration Console Privileged administration Owner: Kevin O'Brien	Tier 2 C High · I High · A Mod	T1078.004 Valid Cloud Accounts (admin) Administrator error (deletion)	V04 1 Global Administrator, no break-glass account, same person is subscription Owner; V15 0 resource locks on the production resource group	R04, R15	**Medium** 9.72 (R04)	—	Entra ID, HVMC-Bastion	All infrastructure changes
Legacy public server Internet-facing host (lab scan target) Owner: Kevin O'Brien	Tier 3 C Low · I Mod · A Low	T1190 Exploit Public-Facing Application	V09 decade-old OpenSSH with ssh-agent forwarding flaw; V10 Apache 2.4.7 with public exploits available	R09, R10	**High** 12.76 (R10)	—	Internet	None (isolated)
VPN Portal Remote access Owner: Kevin O'Brien	Tier 3 C Mod · I Mod · A Mod	T1078 Valid Accounts (third party)	V06 Carlos Diaz account has no expiry date; no business associate agreement on file	R06	**Low** 4.60 (R06)	—	Entra ID	Contractor (Carlos Diaz)
HR Portal & Payroll Business systems Owner: Daniel Osei / Brian Adeyemi	Tier 3 C Mod · I Mod · A Low	Negligent insider	V14 no sanction policy; HIPAA training completion not recorded	R14	**Low** 3.94 (R14)	—	Entra ID	HR (2), Finance (2)

5.1 Observations

- **hvmcehrstorage** has the highest linked ALE and, with the EHR and Entra ID, the most linked risks (4). It is both the most valuable and the most exposed asset, so the storage lockdown (G2) and recovery controls (G8) come first.
- **Entra ID** scores only Medium on its own risks, but the dependency map shows *every* system relies on it. Interconnection raises its effective priority above its score, which is why the register shows dependencies

alongside scores.

- The **Security Monitoring Portal** holds the top-ranked risk (R01). Its dependency on a Log Analytics workspace that doesn't exist means detection is currently unavailable for all assets.
- The **legacy public server** is High on technical severity but Tier 3 with no dependents. It should be isolated or decommissioned rather than heavily invested in.

6. Conclusion and Next Step

HVMC now has an approved, repeatable way to evaluate risk. A four-factor weighted model, with weights derived and consistency-checked by AHP, re-ranked the register so that ransomware recovery and Data-tier segmentation sit behind detection at the top. The BIA set calculated recovery targets: Tier 1 clinical systems need 2–4 hour RTOs and 15–30 minute RPOs. It also showed that today's Azure environment cannot yet meet them, with no compute recovery plan and no blob versioning. The exposure register connects those findings to specific assets and their dependencies. These outputs feed directly into the next rubric, **Risk Mitigation Planning**, which selects and costs the controls to close the gaps.

References

- NIST SP 800-34 Rev. 1, *Contingency Planning Guide for Federal Information Systems* (BIA, MTD/RTO/RPO).
- NIST IR 8286D, *Using Business Impact Analysis to Inform Risk Prioritization and Response* (2022).
- ISO 22301:2019 and ISO/TS 22317:2021, *Business continuity — Business impact analysis*.
- T. L. Saaty, *The Analytic Hierarchy Process* (1980) — pairwise comparison and consistency ratio.
- NIST SP 800-30 Rev. 1; FIPS 199; MITRE ATT&CK Enterprise.
- 45 CFR §164.308(a)(7)(ii)(E), applications and data criticality analysis.
- Microsoft Learn, *Azure Storage redundancy* and *Disaster recovery and storage account failover*.
- HVMC project evidence: HVMC_Risk_Management_Fundamentals.pdf; HVMC_Risk_Assessment_Techniques.pdf; HVMC_Risk_Register.xlsx.